

Montaje de un Laboratorio de Ciberseguridad

Seguridad en Sistemas Informáticos — Tema 1.3

José Luis Martínez

Universidad de Castilla-La Mancha

Curso 2026/27

- 1 Introducción
- 2 Modo hypervisor
- 3 TryHackMe
- 4 HackTheBox
- 5 Docker
- 6 Aplicaciones web vulnerables con Docker
- 7 Repositorios de máquinas y retos

- 1 Introducción
- 2 Modo hypervisor
- 3 TryHackMe
- 4 HackTheBox
- 5 Docker
- 6 Aplicaciones web vulnerables con Docker
- 7 Repositorios de máquinas y retos

- Para comenzar en ciberseguridad, el primer paso es familiarizarse con herramientas, scripts o aplicaciones realizadas por terceros para realizar los primeros ejercicios
- PROBLEMA: Existen muchas técnicas de ataque, de reconocimiento, de post explotación y para cada una de ellas, existen multitud de herramientas que las implementas
- A veces, la puesta a punto de estas herramientas puede ser tediosa
- Cada una puedes estar implementada en diferentes lenguajes
- Necesidad de librerías específicas
- Mantenimiento y actualizaciones

- Existen distribuciones, basadas en Linux, que incorporan una suite completa de herramientas de seguridad, perfectamente funcionales y con “fácil” actualización
- Ejemplos:
 - Kali Linux (<https://www.kali.org/>)
 - Parrot SO (<https://www.parrotsec.org/>)
 - Caine (<https://www.caine-live.net/>)
 - Wifislax (<https://www.wifislax.com/>)

Para desplegar las distribuciones, dos alternativas:

- Nativo en el computador

- Instalación como sistema operativo del host anfitrión
- Ventajas:
 - más rápido y estable
- Desventaja:
 - Usuarios poco familiarizados con Unix, puedes ser incómodo

- Virtualizado

- Corren en tu sistema operativo anfitrión (un Windows, por ejemplo) de manera virtual sobre un hypervisor
- Ventajas:
 - Mantiene tu PC con su configuración natural
- Desventaja:
 - Más inestable, se necesitan más recursos,...

Hypervisores:

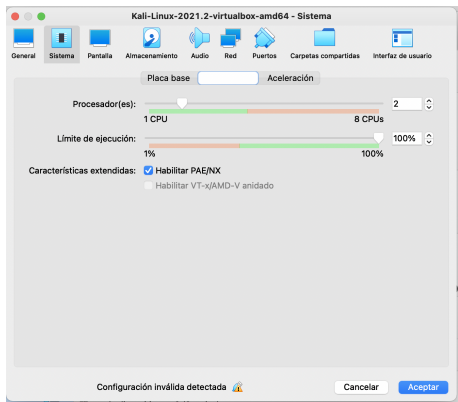
- VirtualBox (<https://www.virtualbox.org/>)
 - VMWare (<https://www.vmware.com/es.html>)
- Mi recomendación:
 - para usuarios nóveles, usar un hipervisor
 - para usuarios con destreza en sistemas unix, podéis animaros a probarlo como SSOO anfitrión

- 1 Introducción
- 2 Modo hypervisor**
- 3 TryHackMe
- 4 HackTheBox
- 5 Docker
- 6 Aplicaciones web vulnerables con Docker
- 7 Repositorios de máquinas y retos

Modo hypervisor

Importar servicio virtualizado (carga .ova). Configuración recomendada:

Habilitar PAE/NX

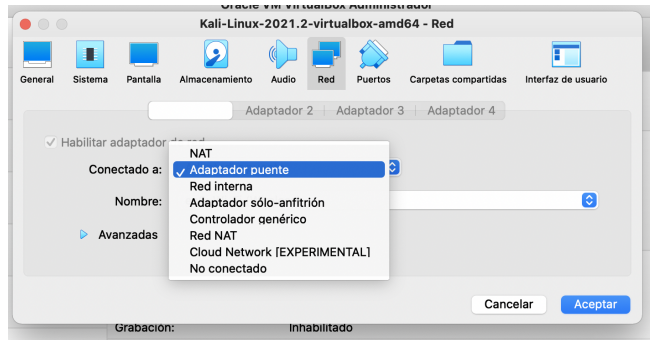


Deshabilitar el audio



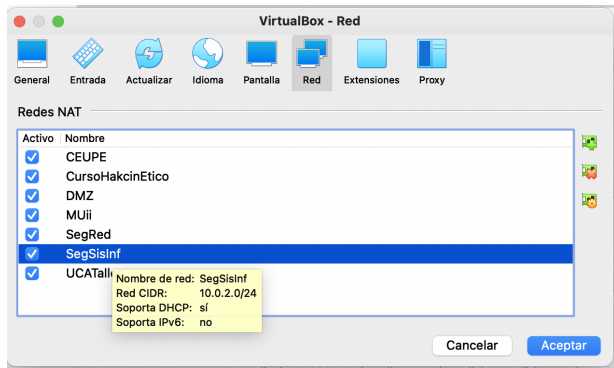
Modo hypervisor

- Importar servicio virtualizado (carga .ova)
- Configuración: Adaptador de red
 - modo puente: tenemos una IP del mismo segmento de red que la máquina anfitrión (donde corre virtualbox)



Modo hypervisor

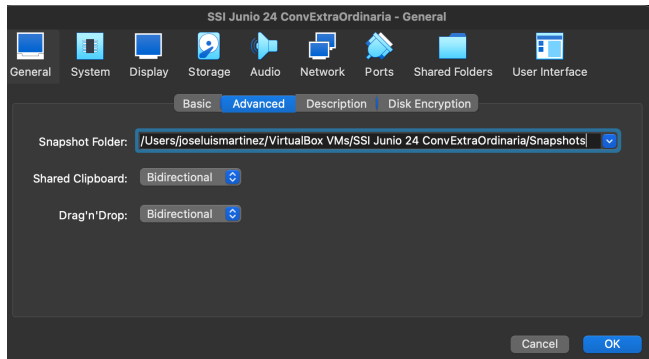
- Importar servicio virtualizado (carga .ova)
- Configuración: Adaptador de red
- Red NAT: El host anfitrión crea una red NAT con Ips privadas en la que estará el host virtualizado. El host hace de Gateway
- Necesario crear la red nat en el menú VirtualBox->Preferencias->red



Modo hypervisor

Arrancamos la Máquina:

- user: kali y pass: kali
- Actualizar:
 - sudo apt-get update
 - sudo apt-get upgrade
 - sudo apt-get install -y virtualbox-guest-x11
- Añadir además esta opción:



Mejorar tamaño de la barra de. . .

- Mejorar tamaño de la barra de tareas, tamaño de letra de la terminal
- Cambiar el teclado de inglés a castellano
 - setxkmap es
- Cambiarlo de manera permanente
 - En el menú de aplicaciones - > Keyboard
 - en la pestaña Layout, seleccionar teclado “Spanish (deadtilde)”
- Tamaño de ventana:
 - Menu apperence

Modo hypervisor

Instalar herramientas interesantes

- `sudo apt-get install locate`
- `sudo apt-get install gedit`
- Cherry Tree
 - <https://github.com/giuspen/cherrytree>
 - Preferencias en Cherry Tree: fichero configuración
- Lo primero de todo comprobamos la shell en la que se esta trabajando. Recuerda que \$\$ se corresponde con el pid del proceso actual.
- `ls -l /proc/$$/exe`
- Vídeos de s4vitar para tunearte el entorno como un verdadero hacker XD:
 - Vídeo de s4vitar (1)
 - Vídeo de s4vitar (2)
- Tutorial de Kali Linux

- Descargar Metasploitable2
- Metasploitable2 en Docker
- Convertir una máquina Windows en una distribución de seguridad:

- 1 Introducción
- 2 Modo hypervisor
- 3 TryHackMe**
- 4 HackTheBox
- 5 Docker
- 6 Aplicaciones web vulnerables con Docker
- 7 Repositorios de máquinas y retos

- TryHackMe
- Registrarse con mail + password
- Una vez loggeado:
 - Acceso
 - Descarga fichero ovpn y ejecutarlo desde la consola:
 - openvpn nombrefichero.ovpn

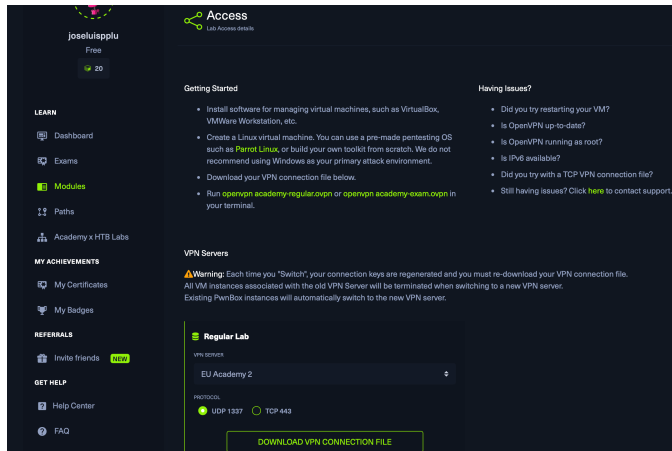
The screenshot displays the TryHackMe VPN interface. On the left, the 'OpenVPN Access Details' panel shows a table with the following information:

OpenVPN Access Details	
VPN Server Name	EU-Regular-1
Server Status	✓
Connected	✗
Internal Virtual IP Address	0.0.0.0

On the right, the 'Networks' panel is active, showing a dropdown menu for 'VPN Server' set to 'EU-Regular-1'. Below this, a message states: 'If you're switching for the first time, you will need to redownload your configuration file. For best performance, please use the server that's geographically closest to you.' At the bottom of this panel are two buttons: 'Download My Configuration File' (green) and 'Regenerate' (blue).

- 1 Introducción
- 2 Modo hypervisor
- 3 TryHackMe
- 4 HackTheBox**
- 5 Docker
- 6 Aplicaciones web vulnerables con Docker
- 7 Repositorios de máquinas y retos

- HackTheBox
- Laboratorio (máquinas):
- Academia:
- Pasos:
 - Descargar fichero ovpn
 - Establecer la conexión con HTB con:
 - openvpn fichero.ovpn



- 1 Introducción
- 2 Modo hypervisor
- 3 TryHackMe
- 4 HackTheBox
- 5 Docker**
- 6 Aplicaciones web vulnerables con Docker
- 7 Repositorios de máquinas y retos

- Docker es una plataforma de contenedores de software que permite crear, distribuir y ejecutar aplicaciones en entornos aislados. Esto significa que se pueden empaquetar las aplicaciones con todas sus dependencias y configuraciones en un contenedor que se puede mover fácilmente de una máquina a otra, independientemente de la configuración del sistema operativo o del hardware.
- Algunas de las ventajas que se presentan a la hora de practicar hacking usando Docker son:
 - Aislamiento: los contenedores de Docker están aislados entre sí, lo que significa que si una aplicación dentro de un contenedor es comprometida, el resto del sistema no se verá afectado.
 - Portabilidad: los contenedores de Docker se pueden mover fácilmente de un sistema a otro, lo que los hace ideales para desplegar entornos vulnerables para prácticas de hacking.
 - Reproducibilidad: los contenedores de Docker se pueden configurar de forma precisa y reproducible, lo que es importante en el hacking para poder recrear escenarios de ataque.

A continuación, se mostrará cómo instalar Docker, cómo crear y administrar contenedores, y cómo usar Docker para desplegar entornos vulnerables para practicar hacking.

- Para instalar Docker en Linux, se puede utilizar el comando:
 - `apt install docker.io`
- Una vez que Docker ha sido instalado, es necesario iniciar el demonio de Docker para que los contenedores puedan ser creados y administrados:
 - `service docker start`
- Ver imágenes descargadas
 - `docker images`
- Descargar imágenes
 - `docker pull ubuntu:latest`

■ Ejecutar un contenedor

- `docker run [opciones] nombre_de_la_imagen`
- `“-d”` o `“-detach”`: se utiliza para arrancar el contenedor en segundo plano, en lugar de en primer plano.
- `“-i”` o `“-interactive”`: se utiliza para permitir la entrada interactiva al contenedor.
- `“-t”` o `“-tty”`: se utiliza para asignar un pseudoterminal al contenedor.
- `“-name”`: se utiliza para asignar un nombre al contenedor.
- `docker run -dit mi_imagen`

■ Una vez que el contenedor está en ejecución, se puede utilizar el comando para listar los contenedores que están en ejecución en el sistema

- `docker ps`. Algunas de las opciones más comunes son:
- `-a`: se utiliza para listar todos los contenedores, incluyendo los contenedores detenidos.
- `-q`: se utiliza para mostrar sólo los identificadores numéricos de los contenedores.

- Detener un contenedor:
 - `docker stop identificador`
- Para ejecutar comandos en un contenedor que ya está en ejecución, se utiliza el comando:
 - `docker exec`
 - `-i`: se utiliza para permitir la entrada interactiva al contenedor.
 - `-t`: se utiliza para asignar un pseudoterminal al contenedor.
- Por ejemplo, si se desea ejecutar el comando “`bash`” en el contenedor con el identificador “123456789”, se puede utilizar la siguiente sintaxis:
 - `docker exec -it 123456789 bash`
 - `docker exec -it 123456789 whoami`

- En la máquina anfitrión se levanta la interfaz de red docker0 conectada a una red tipo 172.17.0.1:
 - ifconfig
- Problema: los contenedores vienen casi sin herramientas para proceder a instalarlas:
 - apt update
 - apt install net-tools
 - apt install iputils-ping
- `docker rm $(docker ps -a -q) --force`: este comando se utiliza para eliminar todos los contenedores en el sistema, incluyendo los contenedores detenidos.

- `docker rm id_contenedor`: este comando se utiliza para eliminar un contenedor específico a partir de su identificador. Es importante tener en cuenta que la eliminación de un contenedor eliminará también cualquier cambio que se haya realizado dentro del contenedor, como la instalación de paquetes o la modificación de archivos.
- `docker rmi $(docker images -q)`: este comando se utiliza para eliminar todas las imágenes de Docker en el sistema.
- `docker rmi id_imagen`: este comando se utiliza para eliminar una imagen específica a partir de su identificador. Es importante tener en cuenta que la eliminación de una imagen eliminará también cualquier contenedor que se haya creado a partir de esa imagen. Si se desea eliminar una imagen que tiene contenedores en ejecución, se deben detener primero los contenedores y luego eliminar la imagen.

- El port forwarding, también conocido como reenvío de puertos, nos permite redirigir el tráfico de red desde un puerto específico en el host a un puerto específico en el contenedor. Esto nos permitirá acceder a los servicios que se ejecutan dentro del contenedor desde el exterior
- `Docker port nombre_imagen`
- para ver puertos
- `ls -l /dev/tcp/localhost/80`
- `Docker run -dit -p 80:80 -name mycontenedor mycontenedor`
- Las monturas permite que un directorio local esté montado en el contenedor
 - `Docker run -dit -p 80:80 -v /home/pplu/descargas:/var/www/html/ -name mycontenedor mycontenedor`
 - `docker run -v /home/usuario/datos:/datos mi_imagen`

Dockerfile

- Es un archivo Dockerfile se compone de varias secciones, cada una de las cuales comienza con una palabra clave en mayúsculas, seguida de uno o más argumentos.
- Algunas de las secciones más comunes en un archivo Dockerfile son:
 - FROM: se utiliza para especificar la imagen base desde la cual se construirá la nueva imagen.
 - RUN: se utiliza para ejecutar comandos en el interior del contenedor, como la instalación de paquetes o la configuración del entorno.
 - COPY: se utiliza para copiar archivos desde el sistema host al interior del contenedor.
 - CMD: se utiliza para especificar el comando que se ejecutará cuando se arranque el contenedor.

- Además de estas secciones, también se pueden incluir otras instrucciones para configurar el entorno, instalar paquetes adicionales, exponer puertos de red y más.
 - ENTRYPOINT: introduce un comando que se debe ejecutar al levantarse el contenedor
 - EXPOSE: publica un puerto en el contenedor
 - ENV: para crear variables de entorno
- `docker build -t mi_imagen:v1 /home/usuario/proyecto/`

```
1 FROM ubuntu:latest
2
3 MAINTAINER José Luis Martinez "pplu"
4
5 ENV DEBIAN_FRONTEND noninteractivite
6
7 RUN apt update && apt install -y net-tools \
8     iputils-ping \
9     curl \
10    git \
11    nano \
12    apache2 \
13    php
14
15 COPY prueba.txt /var/www/html
16
17 EXPOSE 80
18
19 ENTRYPOINT service apache2 start && /bin/bash
```

Ejercicio

- Resuelve este reto de TryHackMe



- Kali Linux en Docker
- Desplegar Docker en Windows
- Distribuciones de seguridad basadas en Docker:
 - offensive-docker
 - pwnbox
 - pwnMachine

- Docker Compose es una herramienta de orquestación de contenedores que permite definir y ejecutar aplicaciones multi-contenedor de manera fácil y eficiente. Con Docker Compose, podemos describir los diferentes servicios que componen nuestra aplicación en un archivo YAML y, a continuación, utilizar un solo comando para ejecutar y gestionar todos estos servicios de manera coordinada.
- En otras palabras, Docker Compose nos permite definir y configurar múltiples contenedores en un solo archivo YAML, lo que simplifica la gestión y la coordinación de múltiples contenedores en una sola aplicación. Esto es especialmente útil para aplicaciones complejas que requieren la interacción de varios servicios diferentes, ya que Docker Compose permite definir y configurar fácilmente la conexión y la comunicación entre estos servicios.

- Repositorio:
- Vulhub
- Cloando:
 - <https://github.com/vulhub/vulhub/tree/master/imagemagick>
 - svn checkout <https://github.com/vulhub/vulhub/trunk/imagemagick>
- cd “directory”
- docker-compose -d up

Comandos Docker (chuleta)

- Imágenes

- `docker pull img` · `docker images` · `docker build -t nombre .` · `docker rmi img`

- Contenedores

- `docker run -d -p 8080:80 --name web img` · `docker ps -a`

- `docker exec -it web bash` · `docker stop/start/rm web` · `docker logs web`

- Volúmenes y redes

- `docker volume create datos (-v datos:/ruta)` · `docker network create red`

- Docker Compose

- `docker compose up -d` · `docker compose down` · `docker compose logs -f`

- Flujo: `build` → `run` → `exec/logs` → `stop/rm`. Compose orquesta varios contenedores.

- 1 Introducción
- 2 Modo hypervisor
- 3 TryHackMe
- 4 HackTheBox
- 5 Docker
- 6 Aplicaciones web vulnerables con Docker**
- 7 Repositorios de máquinas y retos

Aplicaciones Web Vulnerables con Docker

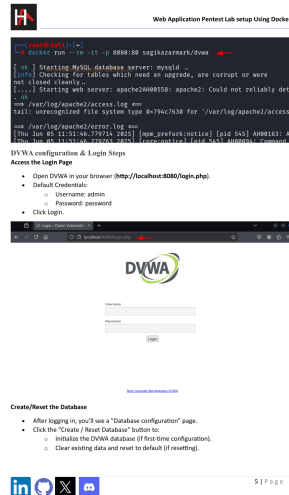
- Entornos de práctica listos en minutos
- Aplicaciones clásicas
- DVWA — PHP/MySQL, 10 categorías OWASP
- OWASP Juice Shop — Node.js, 100+ retos
- OWASP WebGoat — Java EE, lecciones guiadas
- SQLi-Labs — 75 laboratorios de inyección SQL
- bWAPP — PHP, +100 bugs web
- Mutillidae II — LAMP, OWASP Top 10
- APIs y tecnologías modernas
- DVGA — GraphQL, introspección, DoS
- DVRestaurant API — REST, IDOR, JWT bypass

Aplicaciones Web Vulnerables con Docker

- PyGoat — Django (Python), SSTI, A10
- Vulnerabilidades específicas
- SSRF Lab — request forgery, LFI, XXE
- VulnBank — IDOR, transfer forgery
- VulnLab — XSS, SQL, SSRF, path traversal
- WrongSecrets — secretos en config/código
- Zero Health API — BOLA, mass assignment
- Ventajas del enfoque Docker
 - → docker pull / docker run en segundos
 - → Aislamiento total del host
 - → Reset instantáneo: docker rm + docker run
 - → Red interna entre contenedores

Aplicaciones Web Vulnerables con Docker

- DVWA — Damn Vulnerable Web Application
- ¿Qué es?
- Aplicación PHP con MySQL diseñada para ser vulnerable
- 10 categorías del OWASP Top 10 en niveles: Low/Med/High/Impossible
- Instalación
- → `docker pull vulnerables/web-dvwa`
- → `docker run -d -p 80:80 --name dvwa \`
- `vulnerables/web-dvwa`
- Primer acceso
- → `http://localhost/setup.php` → Create/Reset Database
- Login por defecto: admin / password



The screenshot shows the DVWA setup process. At the top, a terminal window displays the command `docker run --rm -it -p 8080:80 sagikazarmark/dvwa` and its output, which includes starting the MySQL database server and the Apache web server. Below the terminal, a browser window shows the DVWA login page with fields for Username and Password, and a Login button. The page also includes a link to the DVWA configuration and login steps. At the bottom, there are social media icons for LinkedIn, GitHub, Twitter, and Facebook.

Web Application Pentest Lab setup Using Docker

```
[root@kali:~]# docker run --rm -it -p 8080:80 sagikazarmark/dvwa
[ ok ] Starting MySQL database server: mysqld ..
[info] Checking for tables which need an upgrade, are corrupt or were
not closed cleanly..
[....] Starting web server: apache2AH00558: apache2: Could not reliably det
- ok
==> /var/log/apache2/access.log <==
tail: unrecognized file system type 0=794c7630 for '/var/log/apache2/access
==> /var/log/apache2/error.log <==
[Thu Jun 05 11:51:46.779714 2025] [mpm_prefork:notice] [pid 545] AH00163: A
[Thu Jun 05 11:51:46.779714 2025] [mpm_prefork:notice] [pid 545] AH00163: Command
```

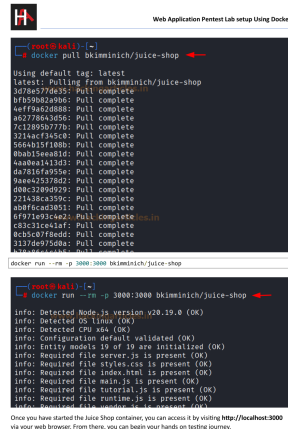
DVWA configuration & Login Steps
Access the Login Page

- Open DVWA in your browser (<http://localhost:8080/login.php>).
- Default Credentials:
 - Username: admin
 - Password: password
- Click Login.

5 | Page

Aplicaciones Web Vulnerables con Docker

- OWASP Juice Shop
- CTF-style con más de 100+ retos
- Score board oculto — parte del reto es encontrarlo
- Instalación
 - → `docker pull bkimminich/juice-shop`
 - → `docker run -d -p 3000:3000 --name juiceshop \bkimminich/juice-shop`
- Primer acceso → `http://localhost:3000`
- Categorías
- XSS, SQLi, Broken Auth, IDOR, Broken Access Control, Sensitive Data Exposure, XXE, Insecure Deserialization
- Retos especiales: Criptografía, JWT, OAuth2



The screenshot shows a terminal window with the following content:

```
Web Application Pentest Lab setup Using Docker

(root@kali)~# docker pull bkimminich/juice-shop
Using default tag: latest
latest: Pulling from bkimminich/juice-shop
3d78e577de35: Pull complete
bfb59b82a9b6: Pull complete
4eff9a62d888: Pull complete
a62778643d56: Pull complete
7c12895b777b: Pull complete
3214ac345c0: Pull complete
5664b15f108b: Pull complete
0bab15eea81d: Pull complete
4aa8ea1413d3: Pull complete
da7816fa955e: Pull complete
9aee425378d2: Pull complete
d80c3289d929: Pull complete
221438ca359c: Pull complete
ab8f6cad3051: Pull complete
6f971e93c4e2: Pull complete
c83c31ce41af: Pull complete
0c85c0f78edd: Pull complete
3137de97560a: Pull complete
17a9e9e1a185: Pull complete
docker run --rm -p 3000:3000 bkimminich/juice-shop

(root@kali)~# docker run --rm -p 3000:3000 bkimminich/juice-shop
info: Detected Node.js version v20.19.0 (OK)
info: Detected OS linux (OK)
info: Detected CPU x64 (OK)
info: Configuration default validated (OK)
info: Entity models 19 of 19 are initialized (OK)
info: Required file server.js is present (OK)
info: Required file styles.css is present (OK)
info: Required file index.html is present (OK)
info: Required file main.js is present (OK)
info: Required file tutorial.js is present (OK)
info: Required file runtime.js is present (OK)
info: Required file vendor.js is present (OK)

Once you have started the Juice Shop container, you can access it by visiting http://localhost:3000 via your web browser. From there, you can begin your hands on testing journey.
```



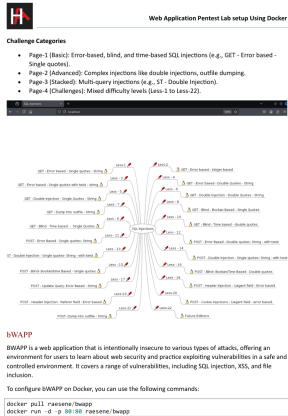
Aplicaciones Web Vulnerables con Docker

- OWASP WebGoat
- Plataforma de aprendizaje con lecciones interactivas. Explica la vulnerabilidad y luego te pide explotarla
- Java EE · Spring · Puerto 8080
- Instalación
 - → `docker pull webgoat/goat-and-wolf`
 - → `docker run -d -p 8080:8080 --name webgoat webgoat/goat-and-wolf`
- Primer acceso → `http://localhost:8080/WebGoat`
- Injection, Broken Auth, XSS, Insecure Direct Object Refs, Security Misconfiguration, Vulnerable Components, CSRF/SSRF, Insecure Deserialization

[illegible]

Aplicaciones Web Vulnerables con Docker

- SQLi-Labs
- PHP · MySQL · 75 laboratorios
- SQL Injection · Error-based · Time-based
- Instalación
 - → `docker pull acgpiano/sqli-labs`
 - → `docker run -d -p 80:80 --name sqli \ acgpiano/sqli-labs`
- Primer acceso → <http://localhost/sql-connections/setup-db.php>
- → <http://localhost/Less-1/?id=1>



Aplicaciones Web Vulnerables con Docker

- bWAPP + Mutillidae II
- +100 vulnerabilidades web, niveles: low/medium/high
- Instalación:
 - → `docker pull raesene/bwapp`
 - → `docker run -d -p 80:80 --name bwapp raesene/bwapp`
 - → <http://localhost/install.php> → Click here to install bWAPP
- Login: bee / bug
- Mutillidae II
- Instalación:
 - → `docker pull webpwnized/mutillidae`
 - → `docker run -d -p 80:80 --name mutillidae \`
 - `webpwnized/mutillidae`
 - → <http://localhost/mutillidae>

Aplicaciones Web Vulnerables con Docker



Aplicaciones Web Vulnerables con Docker

- APIs Vulnerables: DVGA + DVRestaurant
- GraphQL · REST API · JWT · IDOR
- Instalación DVGA:
 - → `docker pull dolevf/dvga`
 - → `docker run -d -p 5013:5013 --name dvga dolevf/dvga`
 - → `http://localhost:5013`
- Modo fácil: header X-DVGA-MODE: Beginner
- Instalación DVRestaurant API
 - → `docker pull thomasdotbiz/dvrestaurant`
 - → `docker run -d -p 3001:3001 --name dvrest thomasdotbiz/dvrestaurant`
 - → `http://localhost:3001/api/docs` (Swagger UI)



Damn Vulnerable GraphQL Application

Damn Vulnerable GraphQL Application is a GraphQL-based web application that is intentionally insecure to various types of attacks, offering an environment for users to learn about GraphQL security and practice exploiting vulnerabilities in a safe and controlled environment.

To configure Damn Vulnerable GraphQL Application on Docker, you can use the following commands:

```
docker pull dolevf/dvga
docker run -t -p 5013:5013 -e WEB_HOST=0.0.0.0 dolevf/dvga
```

```
(root@kali: ~)
# docker pull dolevf/dvga
Using default tag: latest
latest: pulling from dolevf/dvga
Digest: sha256:sha256:5380c9ff9a1e5d725e9abca7b189c63a35a2a73bda79c957
Status: Image is up to date for dolevf/dvga:latest
docker.io/dolevf/dvga:latest

(root@kali: ~)
# docker run -t -p 5013:5013 -e WEB_HOST=0.0.0.0 dolevf/dvga
DVGA Server Version: 2.1.2 Running ...
```



- 1 Introducción
- 2 Modo hypervisor
- 3 TryHackMe
- 4 HackTheBox
- 5 Docker
- 6 Aplicaciones web vulnerables con Docker
- 7 Repositorios de máquinas y retos**

- Vulhub:
 - <https://www.vulnhub.com>
- Hackmyvm:
 - <https://hackmyvm.eu>
- TheHackerLab:
 - <https://thehackerslabs.com>
 - Máquinas: <https://thehackerslabs.com/seguridad-ofensiva/>
 - Contenedores (Docker): <https://dockerlabs.es>
- PentesterLab:
 - <https://pentesterlab.com/exercises>
 - (algunos son free)
- Offsec:
 - <https://portal.offsec.com/dashboard>

¡Gracias!

Seguridad en Sistemas Informáticos — Tema 1.3